ASSESSMENT PRELIMINARE
GDPR

Rif. **Sezione D** del Piano di Intervento

Data audit	
Sede operativa oggetto dell'audit	
Account esecutore dell'audit	
Revisione audit	n.

Il datore di lavoro	**Il tecnico/Account**

Sommario

PREMESSA **3**

DOMANDE INTRODUTTIVE **4**

SEZIONE 1. OBBLIGHI FONDAMENTALI **5**

SEZIONE 2. SICUREZZA E MISURE TECNICHE **8**

SEZIONE 3. TRASPARENZA E DIRITTI DEGLI INTERESSATI **10**

SEZIONE 4. ALTRI ADEMPIMENTI **10**

APPENDICE **12**

RIFERIMENTI NORMATIVI 12

ALCUNI CASI DI NON CONFORMITÀ 12

PREMESSA

La presente checklist è uno strumento operativo a supporto delle attività di assessment preliminare in materia di protezione dei dati personali (GDPR), nell'ambito della Consulenza Stone Global Service +

È importante ricordare infatti che le normative in materia di compliance (Sicurezza sul lavoro, Sicurezza dei Dati, Ambiente e Antincendio) sono per loro natura integrate ed esprimono la loro massima efficacia ed efficienza quando affrontate con un approccio sinergico.

L'obiettivo della presente checklist è fornirti un quadro chiaro, strutturato e misurabile dello stato di conformità dell'organizzazione rispetto agli adempimenti previsti dalla normativa vigente.

Attraverso la compilazione della checklist, vengono analizzate le principali aree di rischio e di adempimento privacy, consentendo di attribuire un punteggio oggettivo a ciascun ambito e di individuare le priorità di intervento.

Gli ambiti esaminati sono i seguenti:

- La predisposizione di documentazione;
- L'organizzazione degli adempimenti;
- La messa in sicurezza dei dati con riguardo all'asset informatico.

L'esito finale, espresso in una scala di rischio complessiva, rappresenta non soltanto una fotografia del livello attuale di conformità, ma soprattutto uno strumento di valore per l'azienda: un punto di partenza concreto per comprendere quali misure siano più urgenti, importanti e strategiche da adottare per garantire la corretta gestione dei dati personali.

La checklist ha quindi una duplice funzione:

1. Diagnostica, perché consente di identificare le eventuali criticità o lacune nel sistema privacy aziendale;
2. Orientativa, perché fornisce indicazioni operative per pianificare in modo graduale e mirato gli interventi di adeguamento, massimizzando l'efficacia delle risorse e minimizzando il rischio normativo e reputazionale.

L'obiettivo finale è mettere a disposizione dell'organizzazione uno strumento di autovalutazione ad alto valore consulenziale, capace di trasformare la verifica di conformità in un percorso di crescita, miglioramento continuo e consapevolezza nella gestione dei dati personali.

Al termine della presente verifica, i nostri esperti in materia di GDPR saranno a tua disposizione per assisterti nell'approfondimento degli esiti e per concordare la realizzazione di un piano di intervento finalizzato all'adeguamento.

DOMANDE INTRODUTTIVE

Di seguito una serie di domande che hanno lo scopo di inquadrare la tua organizzazione.

Chiedi dati ai tuoi clienti ad esempio per la predisposizione e l'invio di documenti fiscali, per l'invio di comunicazioni o anche semplicemente per calendarizzare i tuoi incontri o magari per scattare delle foto?	☐ SI ☐ NO	Se la risposta è si vai più a fondo e compila la sezione 1
Hai un sito internet?	☐ SI ☐ NO	Se la risposta è si vai più a fondo e compila la sezione 1.1
Utilizzi strumenti informatici come computer, tablet, cellulare in cui sono presenti dati dei tuoi clienti, dipendenti o fornitori?	☐ SI ☐ NO	Se la risposta è "SI" vai più a fondo e compila la sezione 2
Per tutelare la sicurezza dei tuoi beni, disponi di un impianto di video sorveglianza?	☐ SI ☐ NO	Se la risposta è "SI" vai più a fondo e compila la sezione 3
Per tutelare la sicurezza dei tuoi mezzi disponi di un impianto di geolocalizzazione?	☐ SI ☐ NO	Se la risposta è "SI" vai più a fondo e compila la sezione 3

SEZIONE 1. OBBLIGHI FONDAMENTALI

La prima sezione è dedicata alla verifica degli adempimenti di base previsti dal Regolamento (UE) 2016/679 (GDPR), che costituiscono il fondamento di ogni sistema di gestione della protezione dei dati personali.

Riguarda aspetti quali la tenuta del registro dei trattamenti, la designazione di responsabili e incaricati, la presenza di informative corrette e aggiornate, e l'adozione di procedure organizzative formalizzate.

L'obiettivo è accertare se l'organizzazione abbia implementato in modo stabile e documentato i requisiti minimi di conformità richiesti dalla normativa.

Questa parte consente di comprendere quanto la protezione dei dati sia effettivamente integrata nei processi aziendali e quanto la governance privacy sia strutturata e consapevole.

PUNTO DI CONTROLLO	Esito check
Hai informative privacy aggiornate per clienti, fornitori, dipendenti?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che … (verificare se sono presenti le informative ed eventualmente la loro correttezza) Qualora non presente suggerisci subito di formularle. Se sono presenti verificare: - Che l'informativa per i clienti abbia idonea base giuridica per il trattamento dei dati (contratto, consenso, legittimo interesse) - Verificare che le informative per i dipendenti non prevedano come base giuridica il consenso - Verificare la presenza dell'informativa per i fornitori è che la stessa sia stata inviata a tutti Azioni consigliate: - Aggiornare le informative avendo cura di individuare le corrette base giuridiche - Diffondi le informative inviandole ai fornitori e avendo cura che le stesse siano state ricevute;	
Hai l'informativa esposta oppure se necessario conservi tutti i moduli con i consensi?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: se tratta i dati dei clienti solo per finalità contrattuali, verifica che l'informativa sia esposta nei luoghi dove vengono ricevuti i clienti. Qualora la base giuridica sia il consenso verifica che i moduli siano conservati e facilmente reperibili Azioni consigliate: - Esponi le informative se non è previsto il consenso; - Per quei trattamenti che prevedono il rilascio del consenso archivia in modo sicuro I moduli di rilascio del consenso;	

PUNTO DI CONTROLLO	Esito check
- Addestra I tuoi collaboratori a supportare gli interessati nella lettura dell'informativa ed eventualmente nella ricezione e conservazione dei consensi;	
Hai nominato i tuoi fornitori come Responsabili del trattamento (es. consulenti, hosting, software)?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare: - che tutte le nomine siano state sottoscritte; - che sia sta effettuato l'audit di controllo anche attraverso la somministrazione di un test In caso di mancata sottoscrizione - Procedere all'invio e alla ricezione dei documenti firmati; - Effettuare audit di controllo per evitare di essere sanzionato per la scelta del tuo fornitore	
Hai fornito istruzioni scritte ai tuoi dipendenti o collaboratori che trattano dati personali?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che - Siano presenti nomine ad autorizzato al trattamento specifiche in base alla mansione; - Verifica che siano descritta le attività che il dipendente può effettuare e le istruzioni su come gestire i dati e le apparecchiature informatiche Azione consigliate se la risposta è no - Redigere e far sottoscrivere ai collaboratori le nomine ad autorizzato avendo cura di che il document rispecchi I trattamenti effettivamente svolti dal collaboratore; - Se non son presenti istruzioni, indicare le misure di sicurezza, come archiviare i dati cartacei in luoghi sicuri, gestire l'autentificazione all'accesso ai pc etcc	
Hai un Registro dei trattamenti aggiornato e completo?	☐ SI ☐ NO ☐ N.A.
Verificare che il registro comprenda tutti i trattamenti effettuati dal titolare Base minima: - Clienti - Dipendenti - Fornitori Se le risposta è no: - Compila al più presto il registro magari servendosi delle FAQ del Garante; - Qualora non fossero censiti tutti I trattamenti (ad esempio marketing, video sorveglianza etcc.) aggiorna il documento - Per I trattamenti di dato sanitario evidenziare lo specifico trattamento;	

PUNTO DI CONTROLLO	Esito check
- Se tratti dati per conto di altri redigi anche il registro da Responsabile del trattamento.	
SEZIONE 1.1. ADEGUAMENTO SITO INTERNET	
Sul tuo sito internet è presente la privacy policy e la cookie policy	☐ SI ☐ NO ☐ N.A.
Hai predisposto il banner cookie per il consenso all'utilizzo dei tracciamenti non necessari conforme alle Linee guida del Garante 2021?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che facendo accesso al sito che: - Sia presente una privacy policy; - Sia presente una cookie policy - Ci sia un banner per I consensi ai cookie non necessari o la dicitura: "questo sito utilizza solo cookie necessari al suo funzionamento" - Verificare in caso di presenza di un modulo di contatto che sia presente il link che rimanda alla privacy policy e che siano indicati le finalità per cui quei dati vengono trattati, - Verifica la presenza di un registro dei consensi Cosa devi fare se la risposta è no (o sì a seconda) Adegua il sito internet al più presto, in quanto il controllo dell'Autorità è molto facile da	

SEZIONE 2. SICUREZZA E MISURE TECNICHE

Questa sezione analizza il livello di protezione tecnica e organizzativa dei dati personali, in linea con l'articolo 32 del GDPR.

Vengono esaminate le misure di sicurezza fisiche, logiche e procedurali adottate dall'organizzazione per prevenire accessi non autorizzati, perdite o distruzioni di dati.

Rientrano in quest'ambito la gestione delle credenziali di accesso, la protezione delle reti e dei sistemi informatici, le politiche di backup e conservazione, nonché le procedure di gestione delle violazioni (data breach).

L'obiettivo è valutare se il livello di sicurezza applicato sia adeguato alla natura dei trattamenti e proporzionato ai rischi per i diritti e le libertà degli interessati.

Questa analisi fornisce indicazioni pratiche per rafforzare la resilienza informatica e organizzativa dell'azienda, prevenendo incidenti e riducendo i potenziali impatti legali ed economici.

PUNTO DI CONTROLLO	Esito check
Sono presenti credenziali di accesso ai device e ai gestionali?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che : i device siano protetti da pw e che la stessa sia diversa per ogni utente Cosa devi fare se la risposta è no (o sì a seconda) Suggerire di modificare le pw, adottando pw "robuste";	
Le password sono complesse e cambiate periodicamente?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare Ogni quanto tempo vengono cambiate le pw; quali indicazioni sono state fornite per cambiare le pw; Cosa devi fare se la risposta è no (o sì a seconda) - Redigi una procedura di Cambio pw con cadenza annual; - Redigi una procedura di formulazione di pw complessa;	
Effettui backup regolari dei dati e li conservi in modo sicuro?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che: 1. Esista almeno una copia del backup; 2. Accertarsi su quale mezzo è effettuato il backup; 3. Verificare quali sono le effettive esigenze della cadenza di backup (ad esempio se salva pochi documenti settimanalmente, anche un backup settimanale può bastare; 4. Verificare che il supporto su cui viene effettuato il backup sia dotato di antivirus, firewall, e log di accesso;	

PUNTO DI CONTROLLO	Esito check
Cosa devi fare se la risposta è no (o sì a seconda) Se la risposta è no (i numeri indicano le azioni per le carenza individuate alla lista sopra indacata) 1. Effettuare più copia del backup secondo la prassi 3-2-1; 2. Utilizzare strumenti anche esterni di modo da garantire la resilienza in caso di disastro; 3. Utilizzare backup più stringenti con cadenza giornaliera 4. Acquisto di strumenti di protezione	
I computer e dispositivi aziendali hanno antivirus e aggiornamenti attivi?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che siano presenti e costantemente aggiornati e non siano installati software con licenza gratuita Cosa devi fare se la risposta è no - Installa subito sistemi di protezione e diffida dai software gratuiti presente in rete;	
Hai una procedura per gestire eventuali violazioni dei dati (data breach)?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che siano presenti backup vedi sopra Cosa devi fare se la risposta è no (o sì a seconda) - Predisponi con urgenza misura di backup di modo da garantire la continuità aziandali	
Hai procedure di accesso al dato di modo da monitorare chi ha avuto accesso agli archivi?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che sia presente un registro dei log di accesso Cosa devi fare se la risposta è no (o sì a seconda) - Predisponi registro	

SEZIONE 3. TRASPARENZA E DIRITTI DEGLI INTERESSATI

In questa sezione vengono approfonditi gli aspetti legati alla trasparenza del trattamento e alla tutela dei diritti degli interessati, in conformità agli articoli 12–22 del GDPR.

Si valuta come l'organizzazione gestisce le richieste di accesso, rettifica, cancellazione, opposizione o portabilità, e se siano previsti canali e tempi certi per rispondere a tali richieste, oltre che le misure adottate sui siti internet aziendali, se presenti.

La trasparenza è un principio cardine del GDPR e rappresenta la base della fiducia tra l'organizzazione e i suoi interlocutori (clienti, dipendenti, fornitori, utenti).

L'obiettivo della sezione è verificare se l'azienda operi in modo chiaro, accessibile e responsabile verso gli interessati, garantendo un'effettiva tutela dei loro diritti e rafforzando la reputazione e l'affidabilità complessiva dell'organizzazione.

PUNTO DI CONTROLLO	Esito check
Sai come gestire le richieste di accesso o cancellazione dei dati da parte degli interessati?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che: - Sia presente un modulo per le richieste dell'interessato; - Verificare che ci sia una casella di posta elettronica dedicata a ricevere le segnalazioni; - Verificare che ci sia una procedura che consenta di evadere le richieste entro 30 giorni (termine max per legge), Cosa devi fare se la risposta è no (o sì a seconda) - Adotta modelli conformi che prevedano l'acquisizione di un documento di identità per l'evasione della richiesta; - Crea un indirizzo di posta dedicato; - Struttura una procedura ed incarica un soggetto specifico	

SEZIONE 4. ALTRI ADEMPIMENTI

L'ultima sezione comprende una serie di obblighi aggiuntivi che, pur non rientrando tra i requisiti fondamentali, rappresentano elementi qualificanti di una gestione avanzata e proattiva della privacy.

Tra questi rientrano, ad esempio, la videosorveglianza, i dispositivi di geolocalizzazione ed altre misure collegate a tali adempimenti.

Questa sezione consente di misurare il grado di maturità del sistema privacy dell'organizzazione, valutando se siano in atto strumenti e procedure orientati alla responsabilizzazione (accountability) e alla prevenzione del rischio.

L'esito di questa parte offre una visione d'insieme sulla capacità dell'azienda di mantenere nel tempo un modello di conformità solido, evolutivo e sostenibile.

PUNTO DI CONTROLLO	Esito check
Se disponi di un impianto di video sorveglianza ed hai dipendenti, hai provveduto ad effettuare la richiesta di autorizzazione all'installazione al competente Ispettorato del lavoro?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare - Sia presente il documento di autorizzazione; - Verificare che non ci siano state modifiche rispetto a quanto dichiarato; - Verificare che sia esposta la cartellonistica e sia stata predisposta idonea informativa per i dipendenti e per i visitatori; Cosa devi fare se la risposta è no (o sì a seconda) - Presenta istanza; - Aggiorna l'istanza; - Predisponi la documentazione **N.B. se non presenti dipendenti non deve essere richiesta l'autorizzazione all'Ispettorato del lavoro ma devono comunque compiersi gli adempimenti privacy**	
Se i mezzi in utilizzo ai tuoi dipendenti dispongono della geolocalizzazione, hai provveduto a presentare istanza di autorizzazione al competente Ispettorato del lavoro?	☐ SI ☐ NO ☐ N.A.
Istruzioni operative: verificare che : - Sia presente il documento di autorizzazione; - Verificare che non ci siano state modifiche rispetto a quanto dichiarato; - Verificare che sia prevista la vetrofonia sui mezzi geolocalizzati e sia stata redatta idonea informativa per l'utilizzo dei mezzi; Cosa devi fare se la risposta è no (o sì a seconda) - Presenta istanza;	

PUNTO DI CONTROLLO	Esito check
- Aggiorna l'istanza; - Predisponi la documentazione	

APPENDICE.

Riferimenti normativi

(Indicare qui l'elenco e gli estremi dei riferimenti normativi)

Alcuni casi di non conformità

Condotta	Sanzione
Invio di newsletter senza consenso valido o prova del consenso	(sanzioni fino a 70.000 € – Garante, 28/04/2022).
Videosorveglianza senza informativa o cartello conforme	(sanzioni tra 5.000 € e 20.000 €).
Mancata nomina del fornitore IT o cloud come Responsabile esterno	(sanzioni fino a 15.000 €).
Raccolta di dati sanitari senza personale medico qualificato	sanzione 20.000 € – Garante, 2020).